

V. V. D. H. A.
K. M. A. R.

ITA- 1408
Ethical Hacking

COH- Assessment Tool- 3

192424332.

Regno:

26/08/26

U. Udhaya Kumar
192424332

ITA-1408 Ethical Hacking

C04-AT3

1) Cyber Security Assessment of an E-Commerce Web Application

Introduction:

The e-Commerce Application is Affected by Suspicious HTTP Requests, malicious Scripts, hidden directory Access Attempts and Outdated Apache / Software Components. These indicate possible Web Application Attacks, injection Attacks, directory traversal and

Exploitation of Known Vulnerabilities...

Attack Vectors:

- 1) Outdated Apache Servers: Known Vulnerabilities may allow attacks to gain Unauthorized Access
- 2) Poor input Validation: Malicious Script can be inserted into input fields to Cross Site Scripting...
- 3) Directory enumeration: Attacks may discover hidden Files, backup Files, and administrative Directory...
- 4) Injection Attacks: Improperly handled User Input may Allow database or Command Injection...

Using Kali Linux:-

- 1) Reconnaissance: Identify the target's Domain technologies, open ports and services using tools such as Nmap.
- 2) Scanning: Use Nmap and Nikto to identify open services, configuration and known web servers.
- 3) Web testing: Use Burp Suite to intercept HTTP request and test input fields, authentication cookies and parameters.
- 4) Vulnerability Analysis: Use OWASP ZAP for Burp Suite to identify common web vulnerabilities.

Layered Defense:-

- Keep Apache, Linux, Frameworks and Libraries Updated...
- Use Strong authentication and MFA
- Validate input using Allow lists
- Encode output to prevent XSS
- Use HTTPS/TLS
- Apply Least-privilege Permissions
- Monitor Logs and establish an intrusion detection system.
- Perform regular vulnerability assessments and penetration tests.

2) SQL Injection and XSS Security Audit...

Introduction:-

The Financial Application contain SQL Injection and Cross Site Scripting (XSS) vulnerabilities. These Weakness can expose Customer information and Allow Attackers to Execute malicious Scripts.

SQL Injection:

SQL Injection Occur when Untrusted User input is directly included in SQL queries. An Attacker may manipulate Application Parameter to change Unauthorized Records.

XSS

XSS Occurs when malicious Javascript is inserted into a Web page and Executed in Another Users Browser. It can be Used to Steal Session information, modify Page Content or Perform action as the Victim.

Conclusion:-

SQL Injection and XSS can seriously compromise Financial Applications. Secure Coding, Proper Session management, input Validation, Output Encoding and Continuous - Security testing are Essential.

3) Introduction:

An Evil Twin is a Fake Wireless Access point designed to imitate a legitimate wifi network. Employee may unknowingly connect to it allowing Attackers to capture Credentials or intercept traffic.

Attack Process:

- 1) The Attacker identifies the Legitimate Wi-Fi network.
- 2) A Fake Access point is Configuration the Same or Similar SSID.
- 3) The Attacker Attempt may User connect to Fake networks.
- 4) Victims may Receive a Fake Login Page.
- 5) Credentials entered by users can be Captured.

Weakness:

- WPA2-PSK relies on a Shared Password.
- Weak Passwords are vulnerable to guessing.
- User may trust a Familiar SSID without Verifying a network.
- Lack of Wireless monitoring make Rogue AP detect difficult.

Countermeasures:

- 1) Use WPA3-Enterprises or WPA-2 with 802.1x where possible.
- 2) Use certificate based authentication.
- 3) Deploy Wireless Intrusion Detection Prevention System.

Conclusion:

Strong intercept Authentication, Continuous Wireless monitoring Escalation and Employee Awareness can greatly reduce Evil Twin and MITM Risks.

4) Penetration Testing of Wireless and Web Applications:

Introduction:

The Organization has weakness in Both Wireless network and Employee management Application. An Attacker can use these weakness as an Attack Chain to Access Confidential employee Information.

Attack Chain:

Wireless Compromise $\rightarrow$ Network Reconnaissance $\rightarrow$ Port Scanning
 $\rightarrow$ Web Enumeration $\rightarrow$ Vulnerability Identification $\rightarrow$ Exploitation $\rightarrow$
Privilege Escalation $\rightarrow$ Data Access.

Phase: 1 Reconnaissance:

Identify Wireless networks, Connected Devices, IP Addresses and Available Services using authorized Network - Analysis Tools...

Phase: Scanning:

Use Nmap to identify open ports and services. Use Nikto or Burp Suite to Assess the Web Application for Security Weaknesses.

Common

Monitoring: $\Rightarrow$ IDS/IPS $\Rightarrow$ Centralized Logging $\rightarrow$ SIEM $\rightarrow$ Continuous Vulnerability Assessment.

Conclusion:

Security must be implemented at multiple layers protecting only the WiFi only the Web Applications is insufficient. Both network and Application security must work together.

5.) Wireless Deauthentication Attack and Countermeasures:-

Introduction:-

A deauthorization attack is a Wireless Denial of Service (DoS) Attack in which Forged management frame causes Legitimate Wireless Client to disconnect from an Access point.

How the Attack Works:-

Traditional Wifi management Frames were not Always Protected Against Forgery. An Attacker can therefore transmit forged deauthorized frame to Access to come from a Legitimate Access Point. Clients Receiving these frames may disconnect and repeatedly Attempt to Reconnect.

Impact:-

- Loss of network Availability
- Users are Repeatedly Disconnected
- Reduced productivity.

Mitigation:-

- Use WPA3 where Supported
- Enable Protected Management Frames.
- Monitor Access point and Wireless Clients Continuously.

Conclusion:-

Deauthorization attacks exploit Weakness in Wireless Management Frame Protection. Wireless monitors IDS/IPS against Wireless DoS Attacks.